CrunchBite Digital — Compliance & Operations Reference

Document type: Compliance / Operations Reference
Version: 1.1
Owner: CrunchBite Legal, Compliance & Operations

---

1. Payment Security — PCI DSS v4.0

1.1 Scope Reduction via Adyen

CrunchBite Digital uses **Adyen** as the exclusive payment processor across all channels. This design achieves **SAQ-A** scope — CrunchBite systems never see, store, transmit, or process raw cardholder data.

Channel	PCI scope	Method
Mobile app	SAQ-A	Adyen Drop-In SDK; card entry handled in Adyen iframe
Web ordering	SAQ-A	Adyen Drop-In component; card data in Adyen frame
Kiosk	SAQ-A	Adyen Terminal API; physical terminal handles card data
Drive-through	SAQ-A	Adyen Terminal API (PED at window)

Saved cards: Adyen returns a **network token** (Visa/Mastercard token, not a PAN). Token stored in Loyalty Service per member account. No PAN is ever stored in CrunchBite systems.

3DS2 rule: Card-not-present transactions above $25 require 3DS2 authentication unless MIT (Merchant-Initiated Transaction) exemption applies (e.g., subscription or saved card with prior 3DS challenge).

1.2 Quarterly and Annual Requirements

- ASV (Approved Scanning Vendor) scan of external-facing infrastructure: quarterly
- Annual SAQ-A self-assessment submitted to acquiring bank
- Adyen BAA equivalent: Data Processing Agreement (DPA) signed; renewed annually
- Penetration test: annual (external perimeter + web app); critical/high findings remediated within 30 days

---

2. US State Privacy Laws (CCPA and Beyond)

2.1 Applicability

CCPA applies to CrunchBite members in California. Virginia (VCDPA), Colorado (CPA), and Texas (TDPSA) have equivalent requirements. CrunchBite applies the strictest interpretation across all US states.

2.2 Member Rights

Right	Portal feature	Implementation SLA
Right to Know	"My Data" → "Download my data"	45 days (extendable once by 45 days)

Right to Delete	"My Data" → "Delete my account"	45 days; transactional records retained for business purposes
Right to Opt-Out (sale/share)	"Privacy Settings" → "Do Not Sell or Share"	Effective within 15 business days
Right to Correct	"My Profile" → edit fields	Immediate for profile fields; points adjustments via support ticket

Do Not Sell or Share (DNSS) link: mandatory on all CrunchBite web properties; must be in website footer and visible without scrolling.

2.3 Data Retention

Data category	Retention period	Deletion trigger
Order transaction records	7 years (tax/legal)	Cannot be deleted on request
Loyalty point history	3 years after account closure	Account closure
Braze engagement events	2 years	Rolling delete
Device identifiers / session logs	90 days	Rolling delete
Deleted member PII	Anonymised within 45 days	Account deletion request
CCTV / kiosk video	30 days	Rolling; not in scope of this programme

---

3. FDA Menu Labelling

3.1 Requirements (Restaurants with ≥ 20 US locations)

CrunchBite (1,000 stores) is subject to **21 CFR Part 101** FDA menu labelling rules:

- **Calorie count** mandatory on all physical and digital menus at point of ordering
- **Daily calorie reference** statement: "2,000 calories a day is used for general nutrition advice" — must appear on menus
- **Additional nutrition info** (total fat, sodium, carbohydrates, sugars, protein) available on request or digitally

3.2 Digital Channel Implementation

Channel	Calorie display	Additional info access
Mobile app	Calories next to every item name	"Nutrition details" expandable panel per item
Web ordering	Same as mobile	Same as mobile

Kiosk	Calories on menu grid; full panel on item detail	Displayed on item detail automatically
MICROS POS	Not customer-facing; exempt	—

Data source: Nutritional data sourced from **Infor CloudSuite Food & Beverage PIM**. Menu Service pulls data from Infor API; cached in DynamoDB per item. PIM is the single source of truth — no manual overrides in the app.

Allergen display: Major allergens (milk, eggs, fish, shellfish, tree nuts, peanuts, wheat, soybeans, sesame) displayed on item detail pages and kiosk screens. Allergen data managed in Infor PIM.

3.3 UK Requirements — Natasha's Law (2021)

For CrunchBite UK stores (Phase 2 international rollout):

- Full ingredient list and allergen declaration mandatory on all food pre-packaged for direct sale (PPDS)
- Digital menus: allergen information prominently displayed; cannot be "behind a link" for kiosk

---

4. Accessibility

4.1 Standards

Jurisdiction	Standard	Applies to
US	WCAG 2.1 AA + ADA	Web, mobile app, kiosk
UK	WCAG 2.1 AA + Equality Act 2010	UK web and kiosk (Phase 2)

4.2 Kiosk ADA Compliance

- **Accessibility mode** activated via a physical button on the kiosk bezel (required by ADA)
- Accessibility mode enables: larger text, high-contrast theme, JAWS-compatible screen reader mode
- Voice guidance: optional (in-scope for Phase 2)
- Kiosk height: 60" max reach range for seated users (ADA 308.3.1); kiosk hardware spec already compliant

4.3 Mobile and Web

- Screen reader: VoiceOver (iOS), TalkBack (Android), NVDA/JAWS (web)
- Touch targets: minimum 44×44px
- Colour: no information conveyed by colour alone (allergen icons use icon + colour + text label)
- Focus order: logical tab order on all web screens; custom focus management for modal dialogs

4.4 CI Enforcement

- axe-core in Storybook component tests: 0 violations required to merge
- Lighthouse accessibility ≥ 90 in GitHub Actions pipeline
- Kiosk: manual JAWS audit before each kiosk software release

---

5. Operational SLAs and Alerting

5.1 Channel Availability

Channel	Availability target	Measurement window
Mobile app (ordering)	99.9%	Monthly, excluding planned maintenance
Web ordering	99.9%	Monthly
Kiosk	99.5% (per-device)	Monthly; offline mode counts as available
MICROS POS integration	99.95%	Monthly; MICROS downtime is store operator's SLA
KDS (kitchen)	99.9%	Monthly; hardware failure tracked separately

5.2 Speed-of-Service (SOS) Targets

Metric	Target	Alert threshold
Order placed → KDS ticket displayed	< 3 seconds	> 5 seconds (P2 alert)
Order placed → MICROS confirmation	< 5 seconds	> 10 seconds (P2 alert)
86-item propagation to all channels	≤ 60 seconds	> 90 seconds (P1 alert)
Otter webhook acknowledgement	≤ 3 seconds	> 3 seconds (Otter retries; P2 alert to Delivery Gateway on-call)
Loyalty points posting after hold	24 hours ± 1 hour	> 25 hours (P3 alert)

5.3 Incident Severity

Severity	Definition	Response time	Notification
P1 — Critical	Ordering down on ≥ 1 channel; payment failure; menu not loading	15 min	On-call + VP Engineering + Ops
P2 — High	SOS targets breached > 5 min; KDS delayed; Otter webhook failures	30 min	On-call + Engineering lead
P3 — Medium	Dashboard data stale; notification delay; single-store kiosk issue	2 hours	Engineering team
P4 — Low	Cosmetic UI issue; non-critical report incorrect	Next business day	Ticket only

5.4 Deployment Windows

- **Restricted**: No deployments to production 11:00 AM – 2:00 PM local store time (peak lunch) or 5:00 PM – 8:00 PM (peak dinner)
- **Preferred**: Overnight deployments 02:00–06:00 CT
- **Emergency hotfix**: any time with VP Engineering approval and P1 incident open
- **Kiosk software updates**: pushed overnight via SCCM; store must have < 5 orders in queue before update initiates